

AutofocusDiscord — Security, Bug & Error Review

Project: AutofocusDiscord NINA Plugin
Version reviewed: 1.3.1.0 (release build)
Patch applied: 1.3.1.1 (fixes documented in Section 4)
Review date: July 4, 2026
Repository: <https://github.com/chrisflory/AutofocusDiscord>
Reviewer: Automated code review (Bugbot + Security Review + manual verification)

Executive summary: Security posture is **ship-ready** for the plugin’s threat model (local NINA user, user-owned Discord webhook). Six logic bugs were found in edge-case paths; all were fixed in **v1.3.1.1**. Core happy-path behavior (per-run posts, graph preview, digests, webhook validation) is sound.

1. Scope & Methodology

This review covered the v1.3.1.0 release delta (since v1.3.0.1) plus full-plugin security paths:

- Automated bug review (logic, races, null handling, digest timing, UI bindings)
 - Automated security review (webhook SSRF, secrets in logs, path traversal, Discord injection, JSON parsing, TLS)
 - Manual verification of findings against source code
 - Release build validation
- Threat model:** Single-user Windows desktop running NINA; plugin watches `%LocalAppData%\NINA\AutoFocus` ; outbound HTTPS posts to user-configured Discord webhooks only.

2. Security Review

Result: No medium, high, or critical issues found.

Area	Verdict	Notes
Webhook URL / SSRF	Pass	<code>WebhookUrlValidator</code> enforces HTTPS, Discord hosts, and <code>/api/.../webhooks/{id}/{token}</code> path shape on every post path.

Area	Verdict	Notes
Secret exposure	Pass	Webhook URL/token not logged. Logs use sanitized filenames and outcome labels only.
Path traversal	Pass	Fixed AutoFocus folder; <code>GetFullPath</code> + prefix check; <code>IncludeSubdirectories = false; *.json</code> only.
Discord injection	Pass	Role pings validated (17–20 digit ID). Content uses <code>Safe()</code> for <code>@everyone</code> / <code>@here</code> . New live-failure embeds sanitized.
AF JSON parsing	Pass	2 MiB max file size; 500 measure points max; <code>JObject.Parse</code> with typed accessors; no unsafe deserialization.
Network / TLS	Pass	Default <code>HttpClient</code> ; 60s timeout; no certificate bypass added in v1.3.1.0.

2.1 Low-severity / defense-in-depth (optional, not blockers)

- **Embed titles** use raw `Filter` from JSON without `Safe()` . A crafted local AF file could put `@everyone` in an embed title; requires write access to the user's own AutoFocus folder and only affects that user's webhook.
- **TOCTOU**: path containment is checked before file settle/read; re-check immediately before read would tighten hygiene on shared machines.

3. Bug & Error Findings (v1.3.1.0)

Severity	Location	Finding	Status
High	<code>SequenceDigestCoordinator.cs</code>	Sequence digest race on back-to-back runs. <code>OnSequenceFinished</code> is async; <code>PostSequenceDigestAsync</code> re-read reports at post time. If the next sequence starts during wait/post, <code>BeginSequence()</code> clears <code>sequenceReports</code> — digest can be empty, wrong, or throw.	Fixed in 1.3.1.1
Medium	<code>AutofocusLiveFailureMonitor.cs</code>	Live AF failure alerts blocked in digest-only mode. Posting required <code>PostPerRunToDiscord PostFailures</code> even when Post when autofocus ends without a JSON report was enabled.	Fixed in 1.3.1.1
Medium	<code>SequenceDigestCoordinator.cs</code>	Pending post wait skipped. Reports landing after wait-loop timeout but	Fixed in

Severity	Location	Finding	Status
		before final count check could skip <code>WaitForPendingPostsAsync</code> , causing digest before per-run post completes.	1.3.1.1
Medium	<code>Options.xaml</code> / <code>AutofocusDiscord.cs</code>	DiscordEnabled not synced with UI toggle. Master checkbox bound to <code>Enabled</code> only; if <code>DiscordEnabled</code> was off, status showed "Discord posting is turned off" with no way to fix from UI.	Fixed in 1.3.1.1
Low	<code>SessionDigestService.cs</code>	Shutdown digest required Enabled. Disabling monitoring before NINA exit skipped configured shutdown digest despite collected reports.	Fixed in 1.3.1.1
Low	<code>AutofocusRunTracker.cs</code>	lastReportUtc read outside lock. Theoretical race in live failure detection on tight timing; low impact on single-user desktop.	Fixed in 1.3.1.1

4. Fixes Applied (v1.3.1.1)

Fix	Implementation
Sequence digest snapshot	<code>WaitAndSnapshotSequenceReportsAsync</code> returns a frozen report list; <code>PostSequenceDigestAsync(reports)</code> posts from snapshot.
Pending post wait	Always wait for pending per-run posts whenever sequence reports exist, regardless of how the wait loop exited.
Live AF in digest-only	Removed gate requiring per-run/failure toggles; live failure posts only need <code>PostLiveAfFailures</code> , <code>DiscordEnabled</code> , and valid webhook.
UI / DiscordEnabled sync	Master <code>Enabled</code> setter now sets <code>DiscordEnabled</code> to the same value and refreshes status.
Shutdown digest	New <code>PostShutdownDigestAsync</code> bypasses <code>Enabled</code> check; teardown uses it when <code>PostDigestOnShutdown</code> is on.
Thread safety	<code>HasNewReportSince</code> reads <code>lastReportUtc</code> under the tracker lock.

5. Build & Compile

Release configuration builds successfully with `dotnet build -c Release`. Release artifact contains 7 managed/native DLLs per publishing docs. NINA must be closed during deploy if post-build copy targets the plugin folder (DLL lock).

6. Overall Verdict

Category	v1.3.1.0	After 1.3.1.1 patch
Security	Ship-ready	Ship-ready
Core happy path	Ship-ready	Ship-ready
Edge cases	6 known gaps	Addressed

Recommendation: Use **v1.3.1.1** (or later) for production. v1.3.1.0 is acceptable for typical single-sequence overnight use with per-run posting enabled; the patch is recommended for back-to-back sequences, digest-only + live-failure setups, and shutdown digest reliability.